**Title:** OWASP ZAP (Web Application Vulnerability Scanner)
**Subject:** Network & Information Security
**Presented by:** Sahil Kanchan 16010123290
Shlok Gawade 16010123315
Shoumik Trivedi 16010123317

**1. Abstract**
Web application security is a critical aspect of modern computing systems. This project focuses on the use of OWASP ZAP, an open-source vulnerability scanning tool used to detect security flaws in web applications. The report demonstrates the installation, execution, and analysis of vulnerabilities detected using OWASP ZAP. The aim is to understand how automated tools help improve application security.

**2. Objectives**
- To understand web application vulnerabilities
- To study the working of OWASP ZAP
- To perform vulnerability scanning on a web application
- To analyze detected vulnerabilities and their impact
- To learn practical implementation of security testing tools

**3. Introduction**
Web applications are widely used in banking, e-commerce, and education systems. However, these applications are often exposed to various cyber threats such as SQL Injection, Cross-Site Scripting (XSS), and CSRF attacks.

To prevent such attacks, security testing tools are used. OWASP ZAP is one such tool that helps in identifying vulnerabilities before attackers exploit them. It acts as a proxy between the browser and server to monitor and test web traffic.

**4. Features of the Tool**
- OWASP ZAP provides the following key features:
- Automated vulnerability scanning
- Passive scanning (no attack)
- Active scanning (attack simulation)
- Spider (automatic crawling of web pages)
- Intercepting proxy for request/response analysis
- Authentication and API testing
- Add-ons and extensions support

**5. Installation & Setup**

Steps followed:

- Download OWASP ZAP from official website
- Install Java (JDK 17 or higher)
- Install OWASP ZAP software
- Launch the application
- Select “No, do not persist session”
- Open Automated Scan dashboard

**6. Experimentation & Results**

Execution Steps:

- Open OWASP ZAP
- Enter target URL (e.g., http://demo.testfire.net)
- Click on Automated Scan → Attack
- ZAP crawls the website using Spider
- Passive and Active scanning is performed
- Results are displayed in the Alerts tab

Observed Results:

- Multiple requests were generated
- Website pages were crawled automatically
- Vulnerabilities detected in real-time

Example Vulnerabilities Found:

- Cross-Site Scripting (XSS)
- Absence of Anti-CSRF Tokens
- Security Misconfiguration
- Missing Security Headers

Each vulnerability was categorized as:

- High
- Medium
- Low
- Informational

**7. Analysis of Outcome**

The experiment shows that OWASP ZAP can successfully identify vulnerabilities in web applications. It provides detailed reports including:

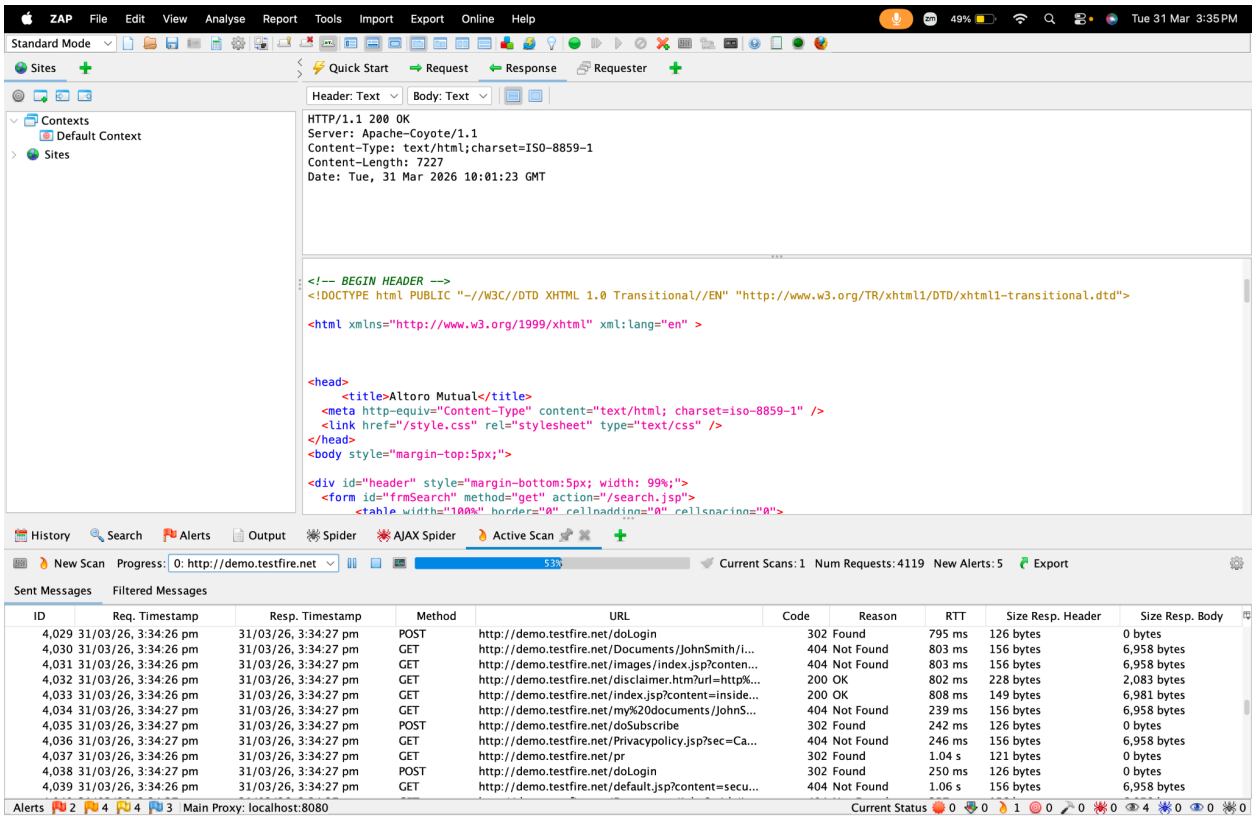
- Vulnerability type
- Risk level
- Affected URL
- Description and evidence

The tool helps developers understand security flaws and take corrective actions. However, some results require manual verification due to false positives.

## 8. Conclusion

Web application security is essential to protect sensitive data and prevent cyber attacks. OWASP ZAP is a powerful and effective tool for identifying vulnerabilities in web applications. It simplifies the process of security testing and helps improve application security. Therefore, OWASP ZAP is widely used by developers, testers, and cybersecurity professionals.

## 9. Implementation screenshots



ZAP File Edit View Analyse Report Tools Import Export Online Help — Tue 31 Mar 3:35 PM

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context
- Sites

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 7227
Date: Tue, 31 Mar 2026 10:01:23 GMT
```

```
<!-- BEGIN HEADER -->
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" >



<head>
    <title>Altoro Mutual</title>
  <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
  <link href="/style.css" rel="stylesheet" type="text/css" />
</head>
<body style="margin-top:5px;">

<div id="header" style="margin-bottom:5px; width: 99%;">
  <form id="frmSearch" method="get" action="/search.jsp">
    <table width="100%" border="0" cellpadding="0" cellspacing="0">
```

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

New Scan Progress: 0: http://demo.testfire.net 100% Current Scans: 0 URLs Found: 234 Nodes Added: 83 Export

URLs | Added Nodes | Messages

| Processed | Method | URI | Flags |
|---|---|---|---|
| | GET | http://jedwatson.github.io/classnames | Out of Scope |
| | GET | http://www.w3.org/1999/xhtml | Out of Scope |
| | GET | http://www.w3.org/1998/Math/MathML | Out of Scope |
| | GET | https://github.com/Starcounter-Jack/JSON-Patch | Out of Scope |
| | GET | http://www.w3.org/1999/xlink | Out of Scope |
| | GET | http://www.w3.org/XML/1998/namespace | Out of Scope |
| | GET | https://mths.be/punycode | Out of Scope |
| | GET | https://github.com/jonschlinkert/repeat-string | Out of Scope |
| | GET | http://www.opensource.org/licenses/mit-license.php | Out of Scope |
| | GET | https://github.com/gregjacobs/Autolinker.js | Out of Scope |
| | GET | https://twitter.com/ | Out of Scope |

Alerts 2 4 4 3 Main Proxy: localhost:8080 Current Status 0 0 1 0 0 0 0 3 0 0 0

ZAP File Edit View Analyse Report Tools Import Export Online Help — Tue 31 Mar 3:35 PM

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context
- Sites

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Date: Tue, 31 Mar 2026 09:58:06 GMT
content-length: 8555
```

```
            <li><a id="MenuHyperLink17" href="index.jsp?content=inside_press.htm">Press Room</a></li>
            <li><a id="MenuHyperLink18" href="index.jsp?content=inside_careers.htm">Careers</a></li>
              <li><a id="MenuHyperLink19" href="subscribe.jsp">Subscribe</a></li>
        </ul>
    </td>
<!-- TOC END -->

   <td valign="top" colspan="3" class="bb">
          <div class="fl" style="width: 99%;">

          <h1>Online Banking Login</h1>

          <!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
          <p><span id="_ctl0__ctl0_Content_Main_message" style="color:#FF0066;font-size:12pt;font-weight:bold;">

          </span></p>

          <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
```

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

- Alerts (13)
  - Cross Site Scripting (Reflected) (2)
  - SQL Injection (3)
  - Absence of Anti-CSRF Tokens (3)
  - Content Security Policy (CSP) Header Not Set (Systemic
  - Missing Anti-clickjacking Header (Systemic)
  - Sub Resource Integrity Attribute Missing
  - Cookie without SameSite Attribute (3)
  - Cross-Domain JavaScript Source File Inclusion
  - Server Leaks Version Information via "Server" HTTP Res
  - X-Content-Type-Options Header Missing (Systemic)
  - Information Disclosure - Suspicious Comments (6)
  - Modern Web Application (4)
  - Session Management Response Identified (3)

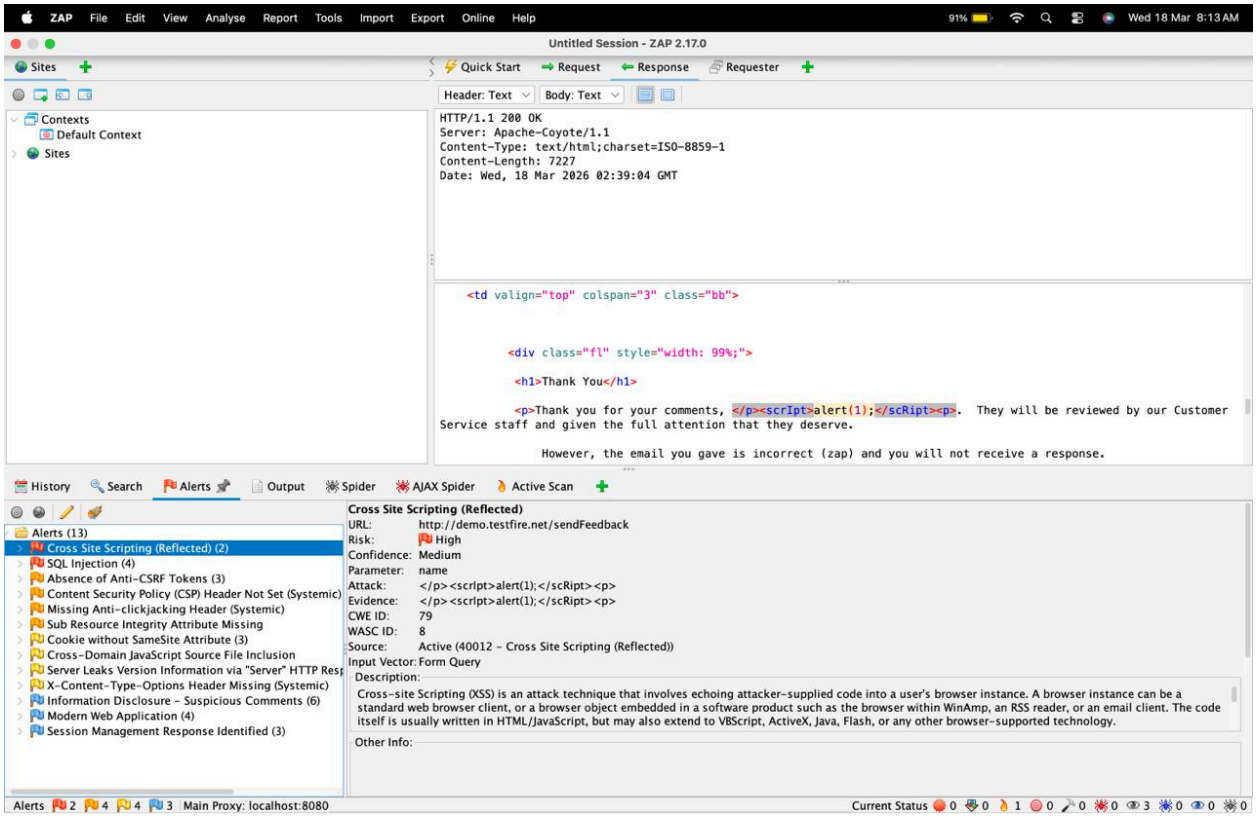
**Absence of Anti-CSRF Tokens**

URL: http://demo.testfire.net/login.jsp
Risk: Medium
Confidence: Low
Parameter:
Attack:
Evidence: <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
CWE ID: 352
WASC ID: 9
Source: Passive (10202 - Absence of Anti-CSRF Tokens)
Input Vector:
Description:

No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the

Other Info:

Alerts 2 4 4 3 Main Proxy: localhost:8080 Current Status 0 0 1 0 0 0 0 2 0 0 0


ZAP File Edit View Analyse Report Tools Import Export Online Help
Wed 18 Mar 8:13 AM
Untitled Session - ZAP 2.17.0
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 7227
Date: Wed, 18 Mar 2026 02:39:04 GMT
<td valign="top" colspan="3" class="bb">

<h1>Thank You</h1>
Thank you for your comments, <scrIpt>alert(1);</scRipt> . They will be reviewed by our Customer Service staff and given the full attention that they deserve.
However, the email you gave is incorrect (zap) and you will not receive a response.
History
Search
Alerts
Output
Spider
AJAX Spider
Active Scan
Alerts (13)
Cross Site Scripting (Reflected) (2)
SQL Injection (4)
Absence of Anti-CSRF Tokens (3)
Content Security Policy (CSP) Header Not Set (Systemic)
Missing Anti-clickjacking Header (Systemic)
Sub Resource Integrity Attribute Missing
Cookie without SameSite Attribute (3)
Cross-Domain JavaScript Source File Inclusion
Server Leaks Version Information via "Server" HTTP Resp
X-Content-Type-Options Header Missing (Systemic)
Information Disclosure - Suspicious Comments (6)
Modern Web Application (4)
Session Management Response Identified (3)
Cross Site Scripting (Reflected)
URL: http://demo.testfire.net/sendFeedback
Risk: High
Confidence: Medium
Parameter: name
Attack: <script>alert(1);</scRipt>
Evidence: <script>alert(1);</scRipt>
CWE ID: 79
WASC ID: 8
Source: Active (40012 - Cross Site Scripting (Reflected))
Input Vector: Form Query
Description:
Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML/JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology.
Other Info:
Alerts 2 4 4 3 Main Proxy: localhost:8080
Current Status

File /Users/shlokgawade/Desktop/2026-03-31-ZAP-Report-.html
School
Gmail
Module 02
LMS
ZAP by Checkmarx Scanning Report
Generated with ZAP on Tue 31 Mar 2026, at 15:32:32
ZAP Version: 2.17.0
ZAP by Checkmarx
Contents
About This Report
Report Parameters
Summaries
Alert Counts by Risk and Confidence
Alert Counts by Site and Risk
Alert Counts by Alert Type
Insights